

DE LA TEORÍA A LA PRÁCTICA

Walkthrough en acción de digitalworld.local SNAKEOIL

Reporte técnico de avance y evidencia audiovisual

Universidad	Universidad Politécnica de San Luis Potosí
Programa	Ingeniería en Tecnologías de la Información
Asignatura	Seguridad Informática CNO IV
Alumno	Juan Francisco Ortega Jiménez
Profesor	Servando López Contreras
Fecha y estado	8 de septiembre de 2026 Avance: análisis y validación en proceso

Alcance autorizado: Todas las pruebas documentadas se realizan exclusivamente contra la máquina vulnerable Snakeoil dentro de una red virtual solo-anfitrión, aislada de Internet y de la red doméstica.

Resumen ejecutivo

Este documento registra la preparación y las primeras fases de un ejercicio de evaluación de seguridad sobre la máquina virtual deliberadamente vulnerable digitalworld.local: Snakeoil. El entorno fue configurado en Oracle VirtualBox con una red solo-anfitrión; Kali Linux se emplea como estación de análisis y Snakeoil como único sistema objetivo autorizado.

Hasta el momento se completaron la identificación de direcciones IP, el descubrimiento del host objetivo, el escaneo de los 65,535 puertos TCP, la identificación de servicios y la enumeración inicial de la aplicación web. La fase de análisis y validación ya se encuentra en proceso: se inspeccionaron de forma no destructiva varias rutas y sus métodos HTTP. No se ha ejecutado ninguna explotación, acceso inicial ni escalamiento de privilegios.

Resultado actual: Snakeoil fue identificada en 192.168.56.103, con los puertos 22, 80 y 8080 abiertos. En el puerto 8080, /users respondió sin autenticación con el usuario patrick y un hash PBKDF2-SHA256; además, /login y /run declararon POST y OPTIONS como métodos permitidos. El impacto definitivo aún requiere validación controlada.

Estado de las doce fases

Fase	Actividad	Estado
1	Configuración del laboratorio	COMPLETADA
2	Inicio y validación de las máquinas	COMPLETADA
3	Identificación de la estación Kali	COMPLETADA
4	Descubrimiento del objetivo	COMPLETADA
5	Escaneo de puertos y servicios	COMPLETADA
6	Reconocimiento de aplicaciones web	COMPLETADA
7	Enumeración manual de rutas y pistas	COMPLETADA
8	Enumeración automática de contenido	COMPLETADA
9	Análisis y validación de vulnerabilidades	EN PROCESO
10	Explotación controlada y acceso inicial	PENDIENTE
11	Post-explotación y escalamiento	PENDIENTE
12	Explicación integral, riesgos y mitigación	PENDIENTE

Objetivo y metodología

Objetivo general

Demostrar la capacidad de aplicar conocimientos teóricos de seguridad informática en un entorno práctico, mediante la realización de un walkthrough detallado y la explicación de las técnicas y metodologías utilizadas para evaluar y vulnerar de forma controlada una máquina virtual deliberadamente insegura.

Objetivos específicos

- Configurar un entorno de virtualización aislado para efectuar pruebas de penetración de forma segura.
- Descubrir el sistema objetivo y utilizar técnicas de escaneo para identificar puertos y servicios expuestos.
- Enumerar servicios, aplicaciones y recursos para obtener información técnica del objetivo.
- Investigar vulnerabilidades asociadas con los componentes identificados y evaluar su viabilidad.
- Seleccionar y adaptar pruebas de concepto únicamente dentro del laboratorio autorizado.
- Obtener acceso controlado al sistema, documentar la post-explotación y evaluar una posible escalada de privilegios.
- Registrar comandos, resultados y capturas de pantalla, explicando cada técnica de forma clara y concisa.
- Preparar un informe reproducible y un video que muestre el proceso completo del walkthrough.

PR -**De la teoría a la práctica: walkthrough en acción (guía y vídeo).****Objetivo general:**

Demostrar la capacidad de aplicar conocimientos teóricos de seguridad informática en un entorno práctico, mediante la realización de un walkthrough detallado y la explicación de las técnicas y metodologías utilizadas para vulnerar una máquina virtual.

Objetivos específicos:

- Configurar un entorno de virtualización aislado para realizar las pruebas de penetración de forma segura.
- Utilizar herramientas de escaneo de puertos y servicios para identificar posibles vectores de ataque.
- Enumerar los servicios y aplicaciones en ejecución para obtener información detallada sobre el sistema objetivo.
- Investigar las vulnerabilidades conocidas asociadas con los servicios y aplicaciones identificados.
- Evaluar el riesgo y la viabilidad de explotar cada vulnerabilidad.
- Seleccionar y adaptar los exploits adecuados para las vulnerabilidades encontradas.
- Escalar privilegios para obtener acceso administrativo.
- Registrar cada paso del proceso, incluyendo comandos utilizados, resultados obtenidos y capturas de pantalla.
- Explicar las técnicas y metodologías utilizadas en cada etapa del ataque.
- Grabar un vídeo de la pantalla durante el proceso de ataque.
- Explicar cada paso del proceso en detalle, utilizando un lenguaje claro y conciso.
- Definir y explicar los términos técnicos utilizados durante el walkthrough.

Duración:

Aproximadamente 07 horas.

El proyecto busca, en primer lugar, preparar un entorno de pruebas seguro, seleccionando y configurando una máquina virtual vulnerable adecuada. A continuación, se realizará un reconocimiento exhaustivo del sistema objetivo, escaneando y enumerando los servicios en ejecución para identificar posibles vectores de ataque. El siguiente paso consiste en analizar las vulnerabilidades presentes en el sistema, investigando las vulnerabilidades conocidas y evaluando el riesgo de su explotación. Posteriormente, se procederá a explotar las vulnerabilidades identificadas para obtener acceso al sistema, seleccionando y adaptando los exploits adecuados. Una vez obtenido el acceso, se realizarán actividades de post-explotación para demostrar el control del sistema, estableciendo persistencia y escalando privilegios. A lo largo de todo el proceso, se documentará detalladamente cada paso del ataque, registrando comandos, resultados y capturas de pantalla. Además, se creará un vídeo explicativo del walkthrough, grabando la pantalla y explicando cada paso en detalle. Un aspecto fundamental del proyecto es la explicación de los conceptos teóricos de seguridad informática relacionados con el ataque, relacionando las técnicas utilizadas con los fundamentos teóricos. Finalmente, se presentará un informe completo y un vídeo de alta calidad que documente y demuestre el proceso de ataque.

URL de máquina virtual:

<https://www.vulnhub.com/entry/digitalworldlocal-snakeoil.738/>

Figura 1. Planteamiento, objetivos y alcance proporcionados para el proyecto académico.

Metodología de trabajo

1. Preparación y aislamiento del entorno virtual.
2. Reconocimiento de red y descubrimiento del objetivo.
3. Escaneo de puertos, identificación de versiones y enumeración web.
4. Análisis de vulnerabilidades y comprobación controlada de hipótesis.
5. Explotación autorizada, post-explotación y escalamiento de privilegios.
6. Evaluación del riesgo, propuesta de mitigaciones y documentación final.

Criterio de evidencia: Cada fase conserva una captura legible, el comando o acción realizada, el resultado observado y una interpretación técnica. Las fases aún no ejecutadas permanecen identificadas como pendientes.

1. Configuración del laboratorio

La máquina Snakeoil se distribuye como un dispositivo virtual compuesto por un descriptor OVF, un manifiesto MF y un disco VMDK. El archivo OVF fue utilizado para importar la máquina en VirtualBox, manteniendo juntos los tres componentes.

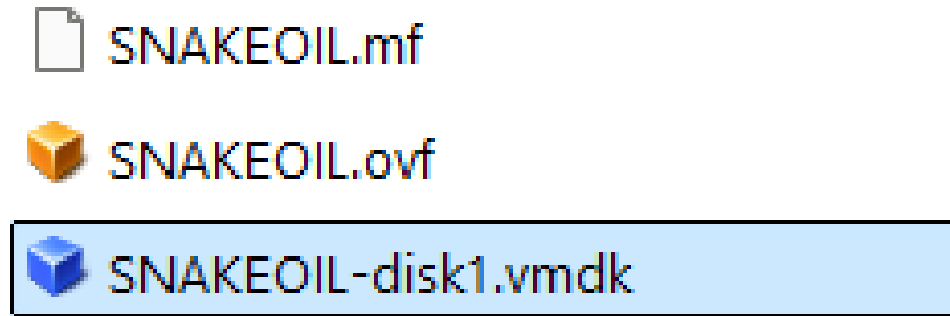


Figura 2. Archivos extraídos del paquete SNAKEOIL: manifiesto, descriptor OVF y disco VMDK.

1.1 Aislamiento de red

Se configuró el adaptador principal de ambas máquinas con el modo Adaptador solo anfitrión y la interfaz VirtualBox Host-Only Ethernet Adapter. Esta topología permite la comunicación directa entre Kali y Snakeoil sin publicar la máquina vulnerable en la red física. El modo promiscuo permaneció denegado y el cable virtual conectado.

Control de seguridad: Snakeoil no utiliza adaptador puente ni NAT. Los adaptadores adicionales deben permanecer desactivados durante la práctica.

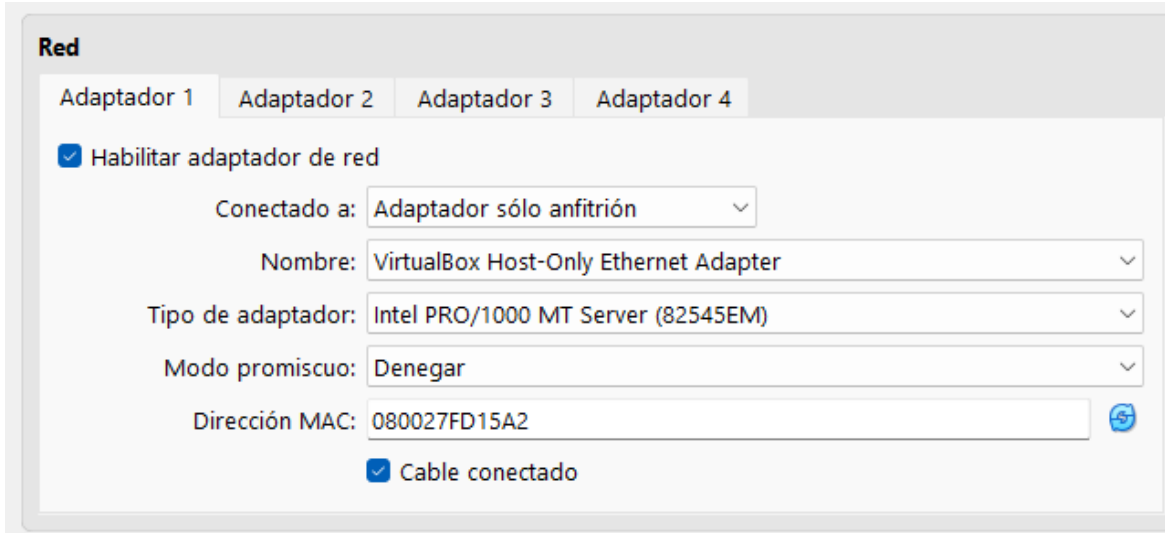


Figura 3. Configuración de red solo-anfitrión de la máquina objetivo Snakeoil.

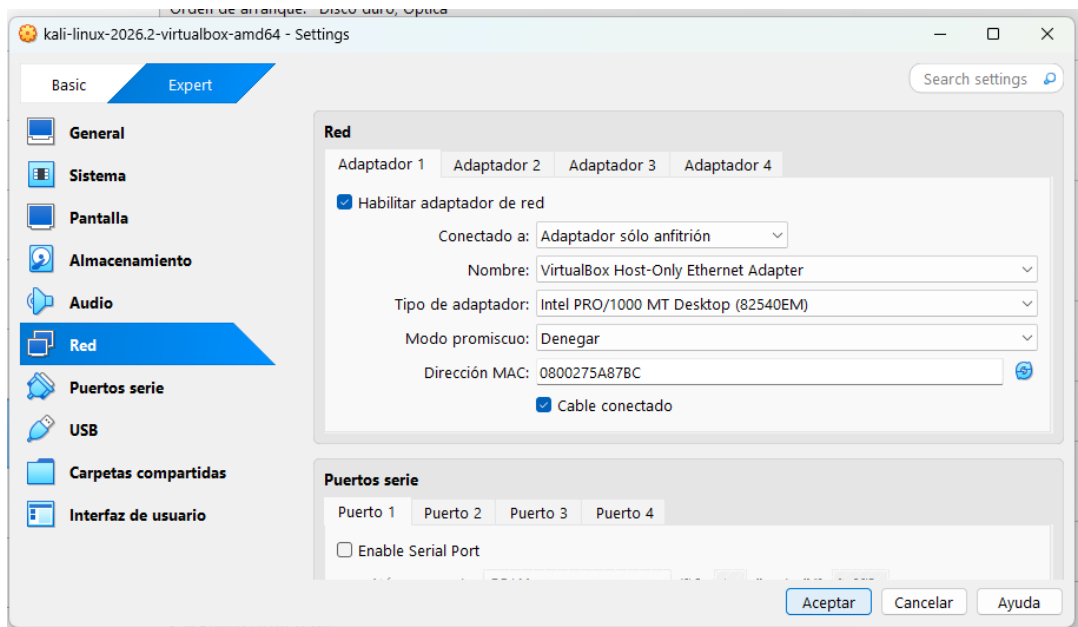


Figura 4. Configuración equivalente de red solo-anfitrión en Kali Linux.

Interpretación: ambas interfaces están conectadas al mismo segmento virtual y pueden intercambiar tráfico local. Esta captura demuestra el límite técnico del alcance de las pruebas.

2. Inicio y validación de las máquinas

Snakeoil inició correctamente sobre Debian 10 y mostró la cuenta local patrick en la pantalla de autenticación. No se intentó iniciar sesión desde la consola, ya que el acceso debe obtenerse como resultado del ejercicio y no mediante credenciales predeterminadas.

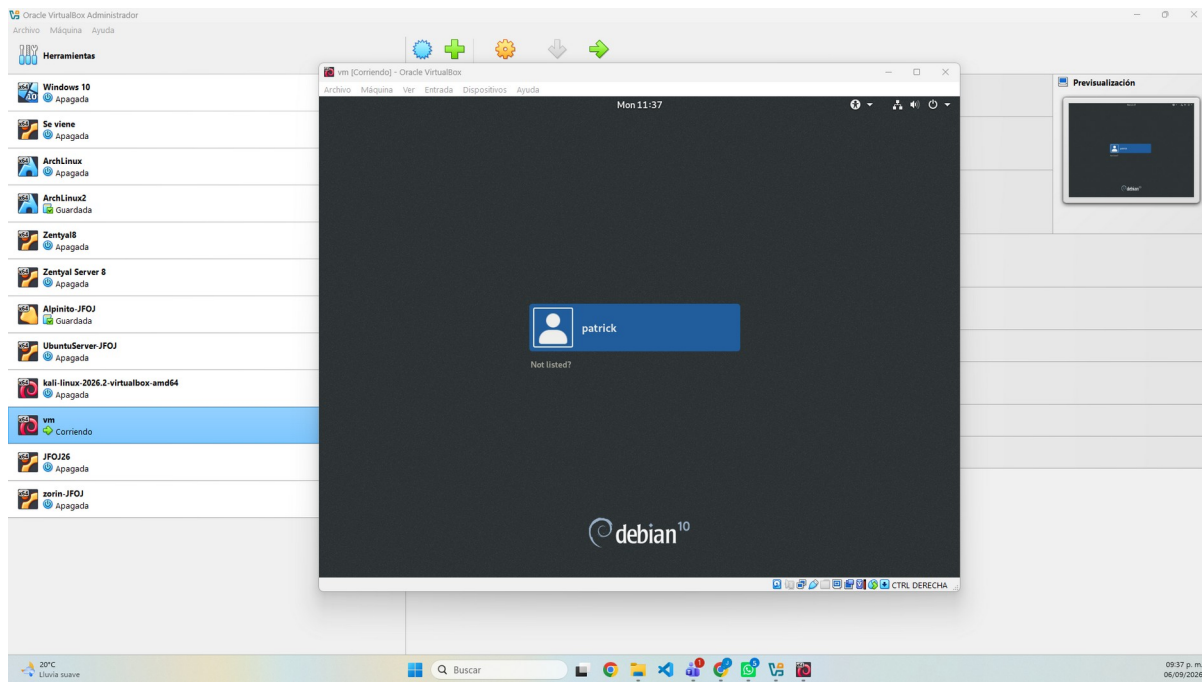


Figura 5. Inicio correcto de Snakeoil y cuenta local visible patrick.

Hallazgo preliminar: El nombre patrick constituye información de enumeración. Más adelante podrá correlacionarse con servicios, publicaciones y mecanismos de autenticación, sin asumir todavía que permita acceso.

3. Identificación de la estación Kali

En la terminal de Kali se ejecutó el siguiente comando para consultar de forma resumida sus interfaces y direcciones:

```
ip -br addr
```

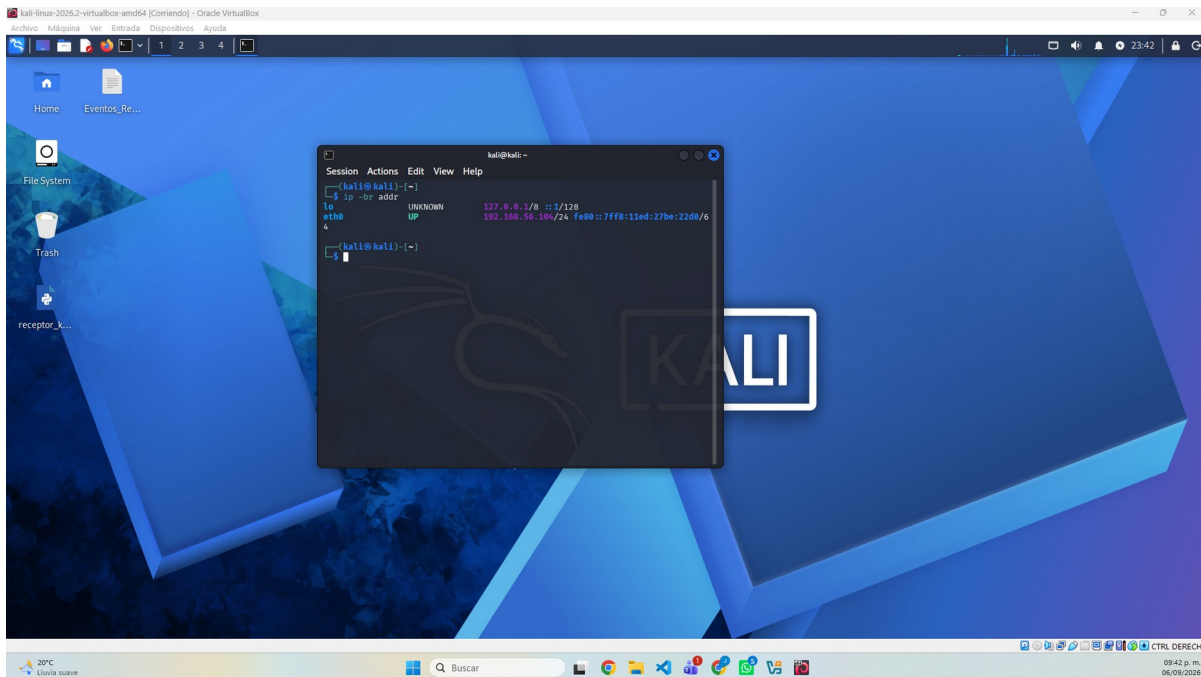


Figura 6. Dirección IPv4 asignada a Kali en la interfaz eth0.

Resultado: la interfaz eth0 se encontraba activa con la dirección 192.168.56.104/24. Por tanto, el segmento del laboratorio corresponde a 192.168.56.0/24.

Inicio sugerido del video: La grabación principal puede comenzar en esta fase, mostrando brevemente la configuración aislada antes de ejecutar el primer comando de reconocimiento.

4. Descubrimiento del objetivo

Se realizó un barrido de descubrimiento sin escaneo de puertos sobre el segmento local:

```
sudo nmap -sn 192.168.56.0/24
```

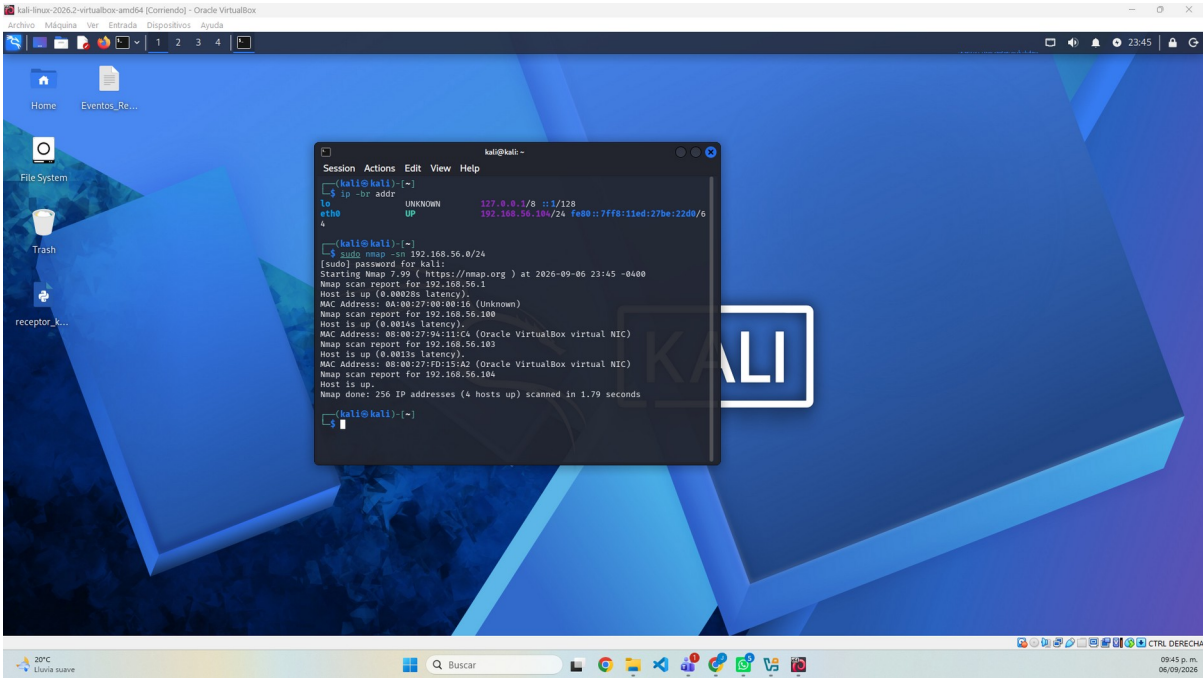


Figura 7. Descubrimiento de hosts activos mediante Nmap.

Nmap detectó cuatro direcciones activas. La dirección 192.168.56.103 se asoció con Snakeoil porque su dirección MAC 08:00:27:FD:15:A2 coincide con la registrada en VirtualBox. Kali corresponde a 192.168.56.104.

Elemento	Dirección IP	Dirección MAC / función
Host de VirtualBox	192.168.56.1	Interfaz solo-anfitrión del equipo físico
Servicio virtual	192.168.56.100	Componente de la red VirtualBox
Snakeoil	192.168.56.103	08:00:27:FD:15:A2
Kali Linux	192.168.56.104	Estación de evaluación

5. Escaneo de puertos y servicios

Con el objetivo identificado se ejecutó un escaneo completo de puertos TCP, servicios, scripts predeterminados y detección aproximada del sistema operativo:

```
sudo nmap -sS -sV -sC -O -p- 192.168.56.103 -oN snakeoil_escaneo_completo.txt
```

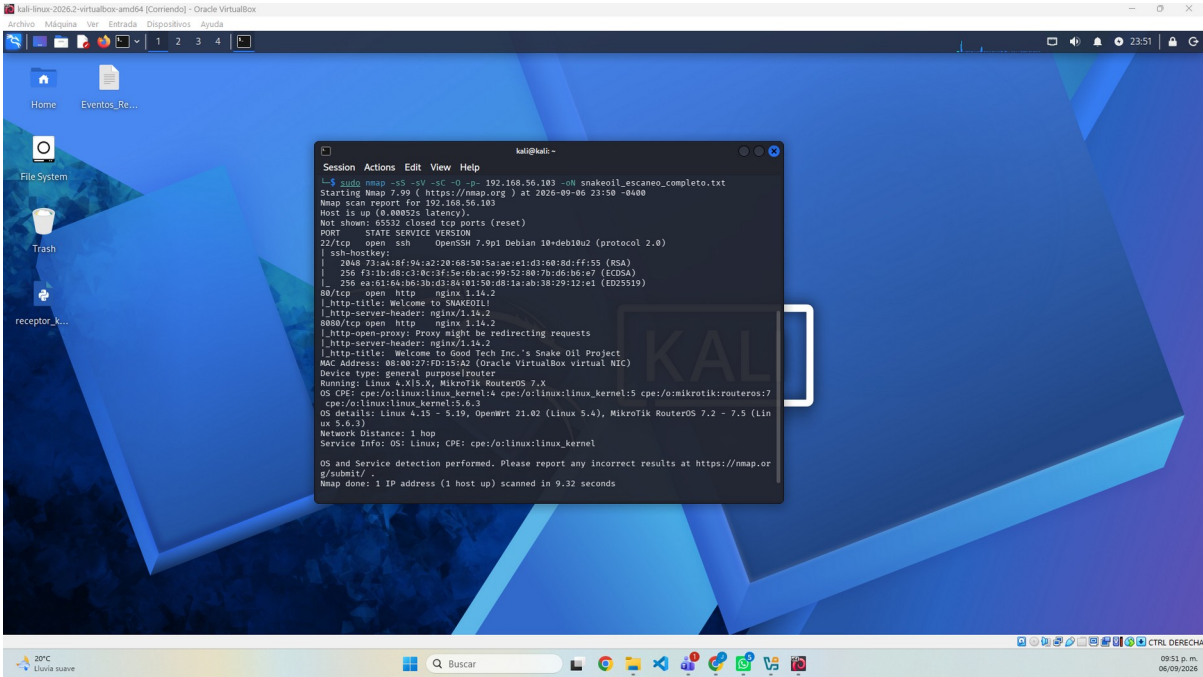


Figura 8. Escaneo completo de puertos y servicios de Snakeoil.

Puerto	Servicio	Versión observada	Interpretación inicial
22/tcp	SSH	OpenSSH 7.9p1 Debian 10+deb10u2	Servicio de acceso remoto; requiere autenticación.
80/tcp	HTTP	nginx 1.14.2	Página de bienvenida de Snakeoil.
8080/tcp	HTTP	nginx 1.14.2	Aplicación web Good Tech Inc.; principal superficie inicial.

Criterio técnico: La versión de un servicio no demuestra por sí sola una vulnerabilidad. Los resultados de Nmap se emplean para orientar la enumeración y posteriormente deberán contrastarse con la configuración real y fuentes confiables.

6. Reconocimiento de aplicaciones web

6.1 Servicio HTTP del puerto 80

El puerto 80 presentó una página estática que confirma que SNAKEOIL está configurada correctamente. El único enlace visible dirige a Google y no forma parte del objetivo local, por lo que no se siguió durante la prueba aislada.

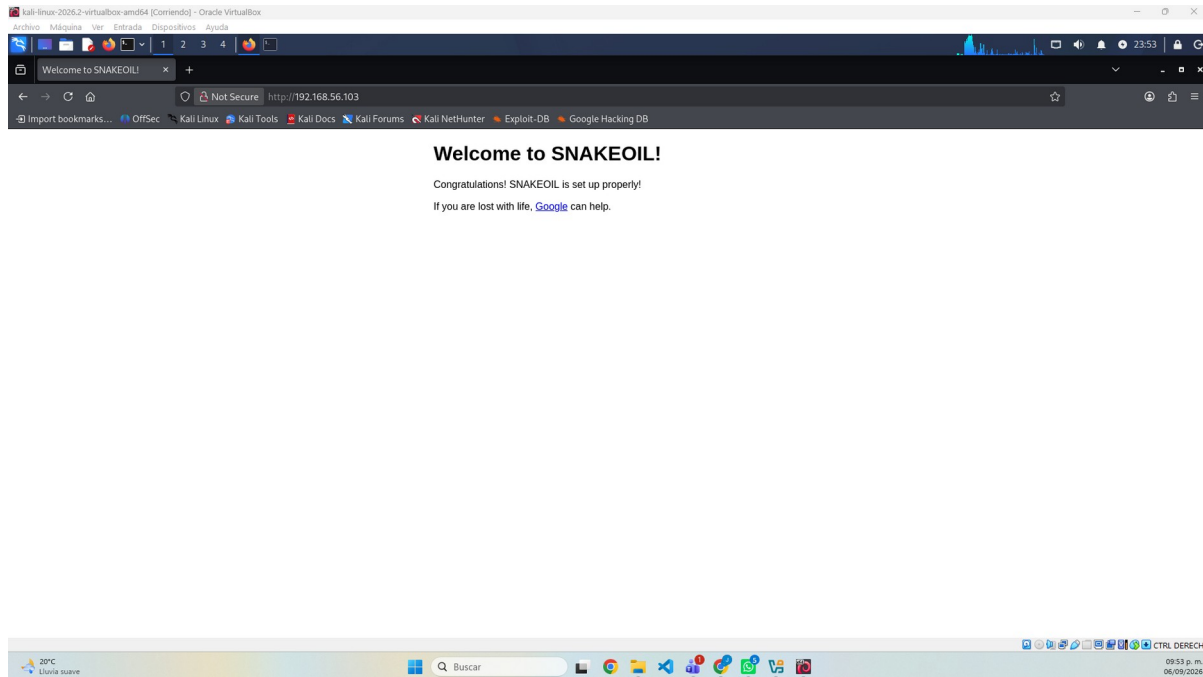


Figura 9. Página de bienvenida expuesta en el puerto 80.

6.2 Aplicación web del puerto 8080

En el puerto 8080 se observó una aplicación de publicaciones denominada Good Tech Inc.'s Snake Oil Project. La página expone enlaces a About, New Post y tres publicaciones, además de controles Edit.

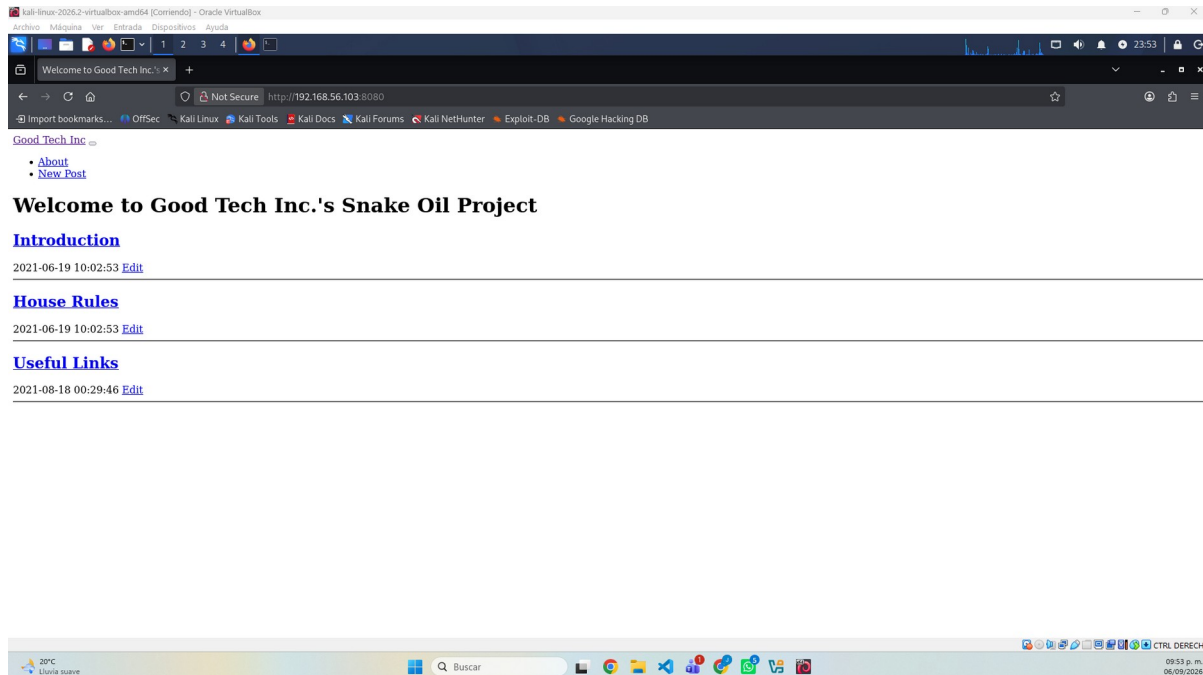


Figura 10. Página principal de la aplicación web en el puerto 8080.

7. Enumeración manual de rutas y pistas

Las publicaciones emplean identificadores numéricos predecibles en la ruta: /1 para Introduction, /2 para House Rules y /4 para Useful Links. Se revisó cada recurso sin modificar datos.

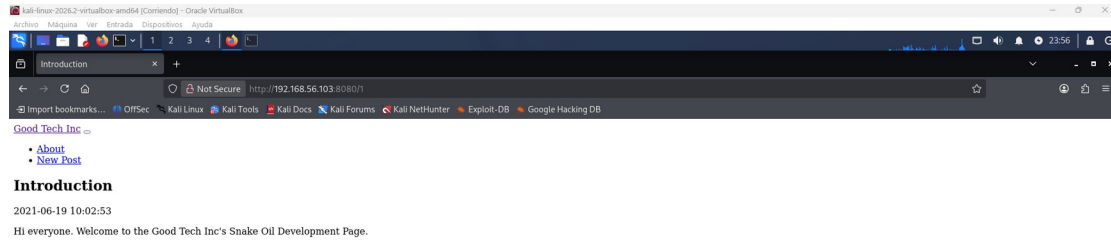


Figura 11. Recurso /1, publicación Introduction.

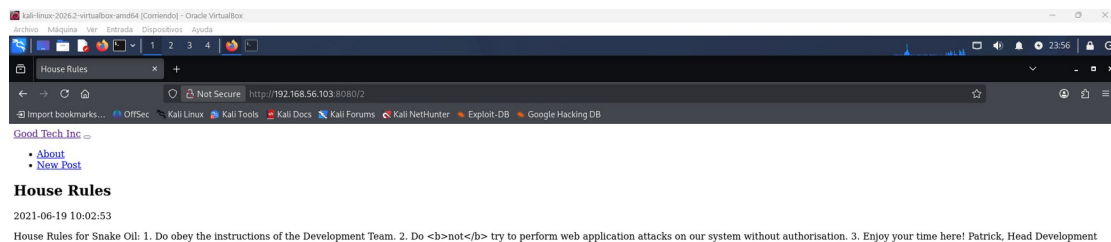


Figura 12. Recurso /2, publicación House Rules firmada por Patrick.

La publicación House Rules confirma que Patrick es responsable de desarrollo. Además, muestra literalmente una etiqueta HTML `<b>not</b>`, observación que deberá conservarse para analizar posteriormente cómo procesa la aplicación el contenido almacenado.

7.1 Pista tecnológica en el recurso /4

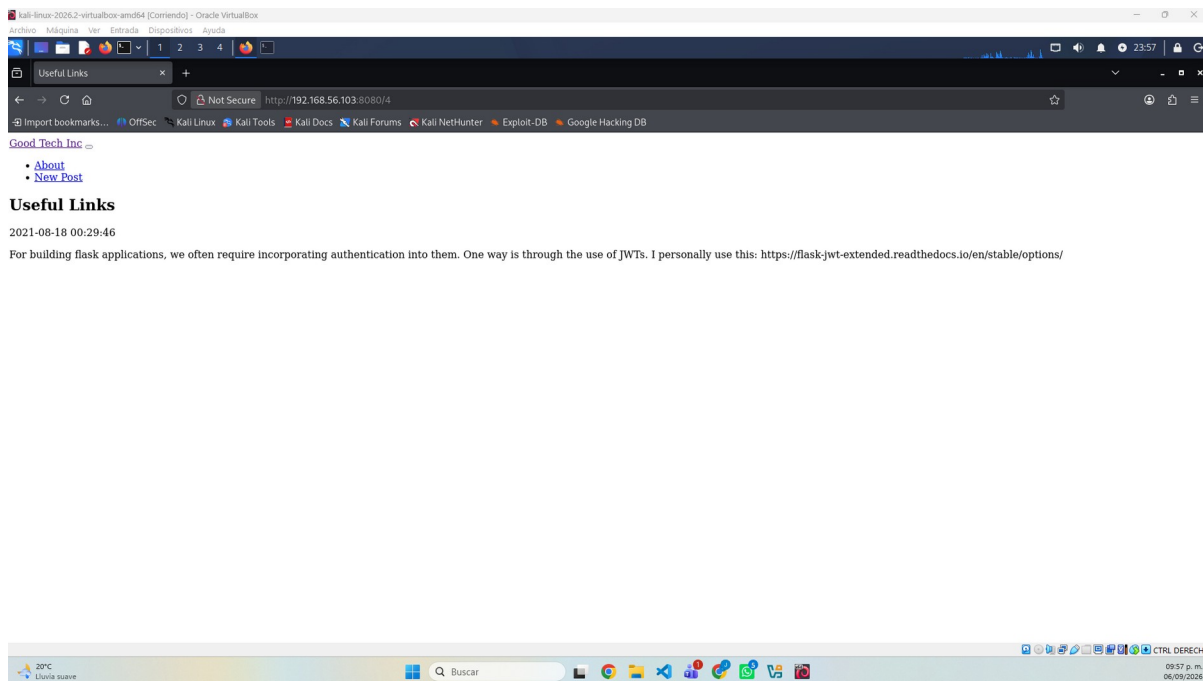


Figura 13. Recurso /4, pista sobre Flask y autenticación mediante JWT.

La publicación Useful Links indica que la aplicación fue construida con Flask y que utiliza JSON Web Tokens (JWT) mediante Flask-JWT-Extended. Este dato orientará el análisis posterior de autenticación, pero no demuestra por sí mismo una falla.

7.2 Comprobación del identificador ausente /3

Debido a que la secuencia visible salta del identificador 2 al 4, se solicitó manualmente /3 para comprobar si existía un recurso no listado.

`http://192.168.56.103:8080/3`

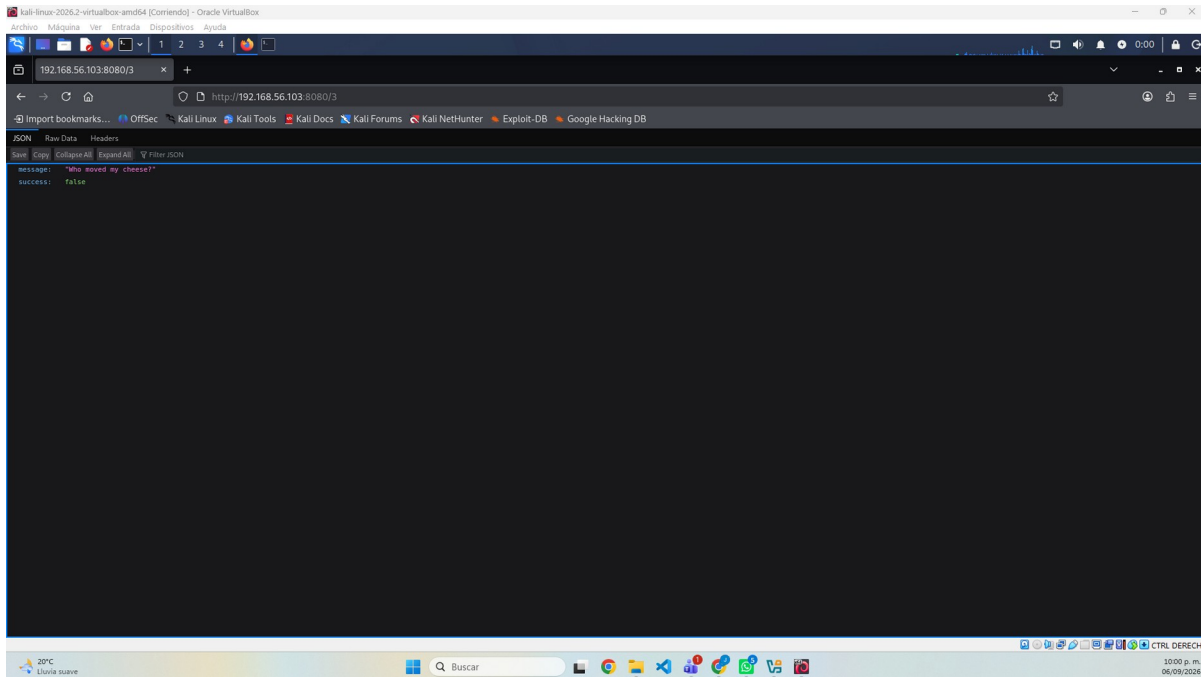


Figura 14. Respuesta JSON personalizada obtenida al solicitar el identificador /3.

La ruta no reveló una publicación; respondió con el mensaje Who moved my cheese? y success: false. El resultado confirma que la aplicación procesa identificadores numéricos y utiliza una respuesta de error personalizada.

8. Enumeración automática de contenido

Para identificar rutas no enlazadas desde la interfaz se utilizó Gobuster con una lista común y extensiones de interés:

```
gobuster dir -u http://192.168.56.103:8080 -w /usr/share/wordlists/dirb/common.txt -x txt,html,py -o gobuster_8080.txt
```

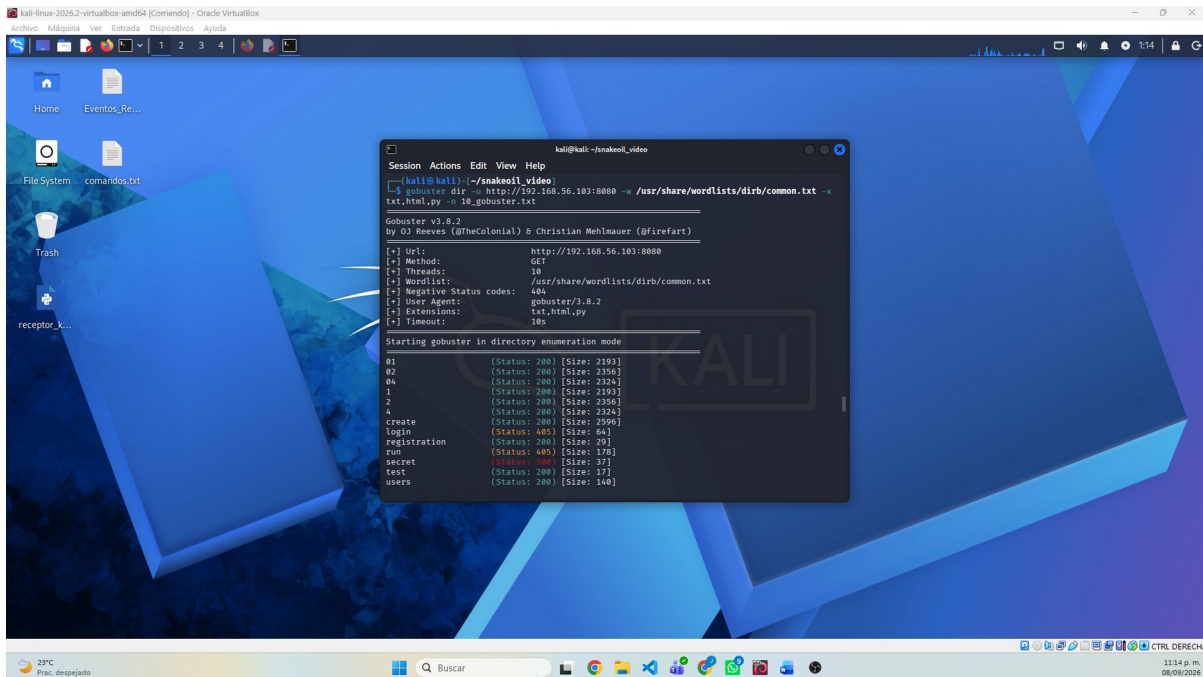


Figura 15. Enumeración de rutas del servicio 8080 mediante Gobuster.

Ruta	Código	Lectura preliminar
/create	200	GET devuelve una página HTML para crear publicaciones.
/login	405	GET no está permitido; OPTIONS declara POST y OPTIONS.
/registration	200	GET devuelve JSON con el mensaje Wrong Method!!!.
/run	405	GET no está permitido; OPTIONS declara POST y OPTIONS.
/secret	500	GET provoca un error interno con respuesta JSON genérica.
/test	200	GET devuelve el objeto JSON {"TestValue": 0}.
/users	200	GET expone el usuario patrick y un hash de contraseña.

Límite del avance: La enumeración automática concluyó y dio paso a una inspección no destructiva mediante GET y OPTIONS. No se enviaron credenciales, cuerpos POST, comandos a /run, cargas útiles ni intentos de explotación.

9. Análisis y validación de vulnerabilidades

Estado: EN PROCESO. Se validaron respuestas y métodos HTTP sin enviar credenciales, comandos ni cargas útiles. La exposición observada en /users queda registrada como hallazgo preliminar; su impacto definitivo se evaluará antes de cualquier prueba de concepto.

9.1 Exposición de información en /users

Una solicitud GET directa a /users obtuvo HTTP 200 y una respuesta JSON sin evidencia de autenticación previa. El contenido reveló el nombre de usuario patrick y un hash de contraseña con el esquema PBKDF2-SHA256 y 29,000 iteraciones. No se recuperó ni se afirma conocer la contraseña en texto claro.

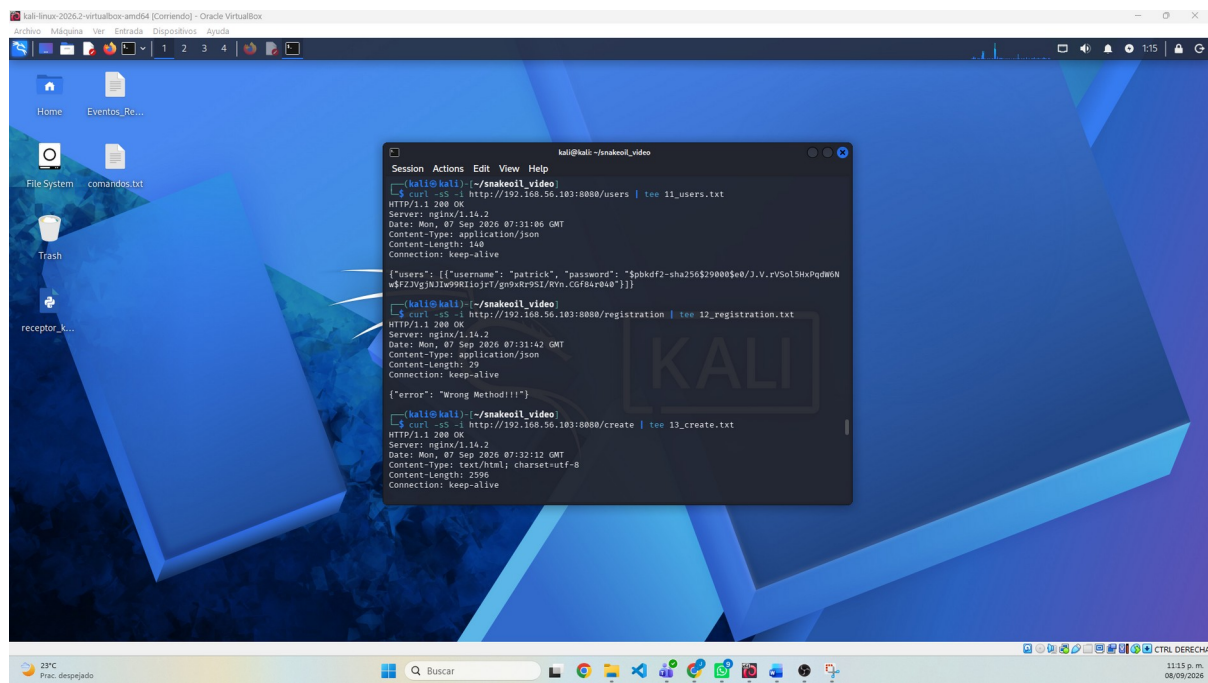


Figura 16. Respuesta de /users y comprobaciones iniciales de /registration y /create.

Aspecto	Evidencia observada	Valoración actual
Acceso	GET /users respondió HTTP 200 sin token visible.	Exposición confirmada
Datos	Usuario patrick y hash PBKDF2-SHA256.	Información sensible
Impacto	Facilita identificación de cuentas y auditoría offline del hash.	Medio, preliminar

La debilidad confirmada es la divulgación innecesaria de material de autenticación. Aunque PBKDF2-SHA256 protege mejor que almacenar contraseñas en texto claro, publicar el hash elimina una barrera de acceso y permite intentar una auditoría offline. La severidad se mantiene como preliminar hasta comprobar la fortaleza real de la contraseña y la relación del usuario con el servicio de inicio de sesión.

9.2 Revisión de /create y /registration

La ruta /create respondió HTTP 200 y entregó una página HTML titulada Create a New Post. El código visible incluye navegación hacia New Post, pero esta observación solo confirma que el formulario o vista se sirve mediante GET; no demuestra que un usuario no autenticado pueda guardar contenido.

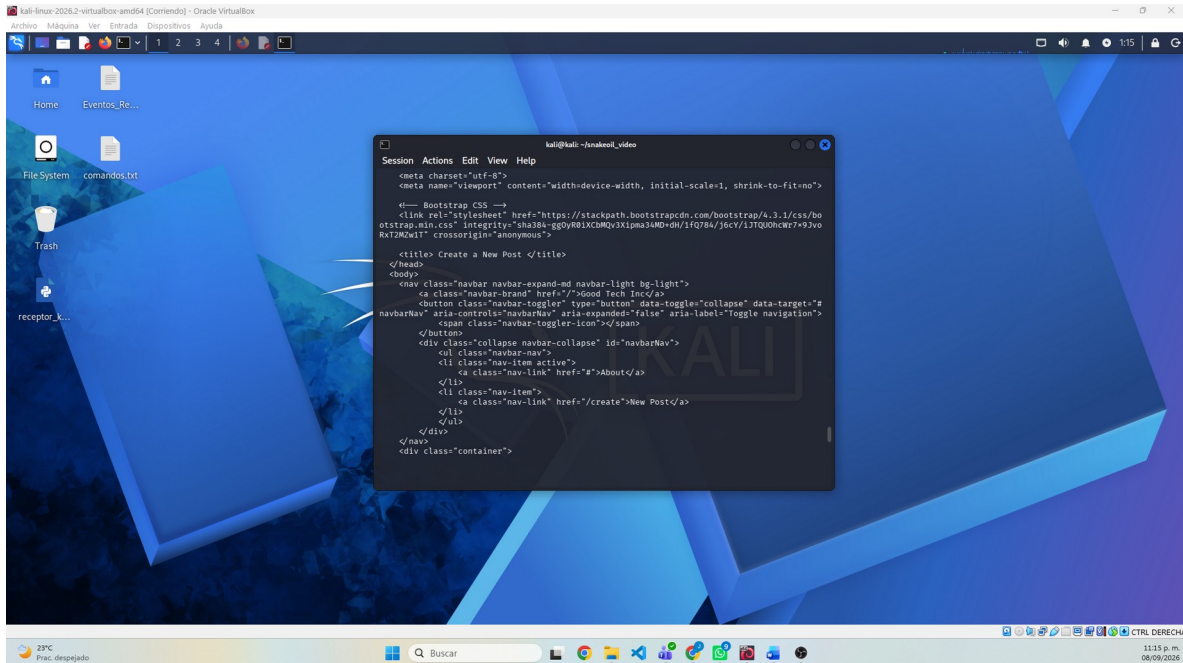


Figura 17. Código HTML entregado por la ruta /create mediante una solicitud GET.

Por otra parte, /registration respondió HTTP 200 a GET, pero el cuerpo JSON indicó Wrong Method!!!. Existe una diferencia entre el código HTTP de transporte y el error comunicado por la aplicación; será necesario identificar el método y el formato esperado antes de evaluar controles de registro.

9.3 Respuestas de /test y /secret

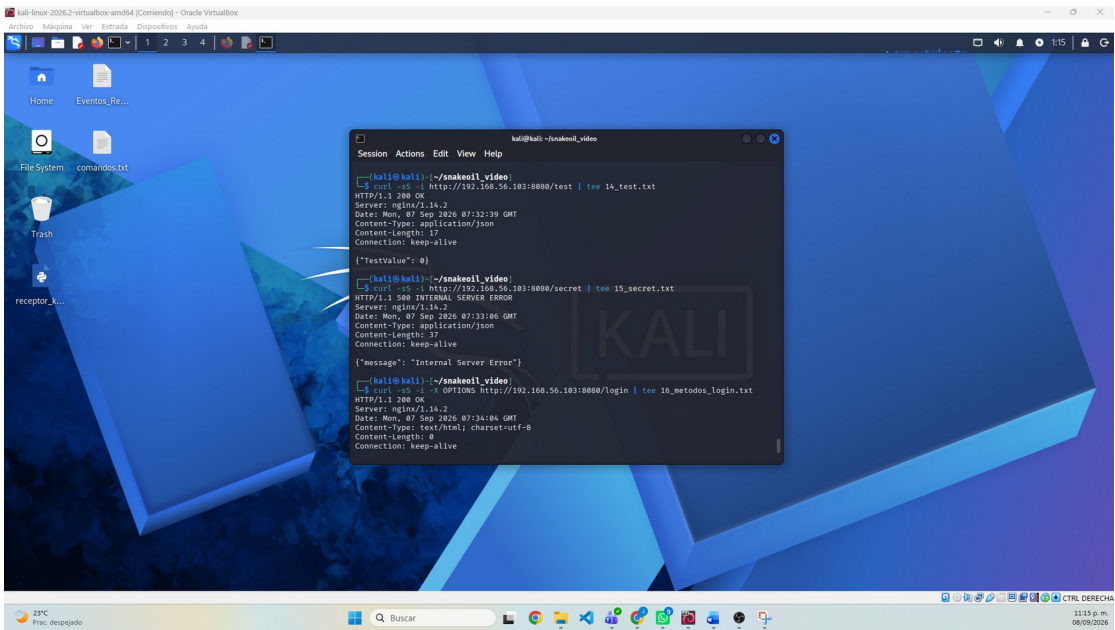
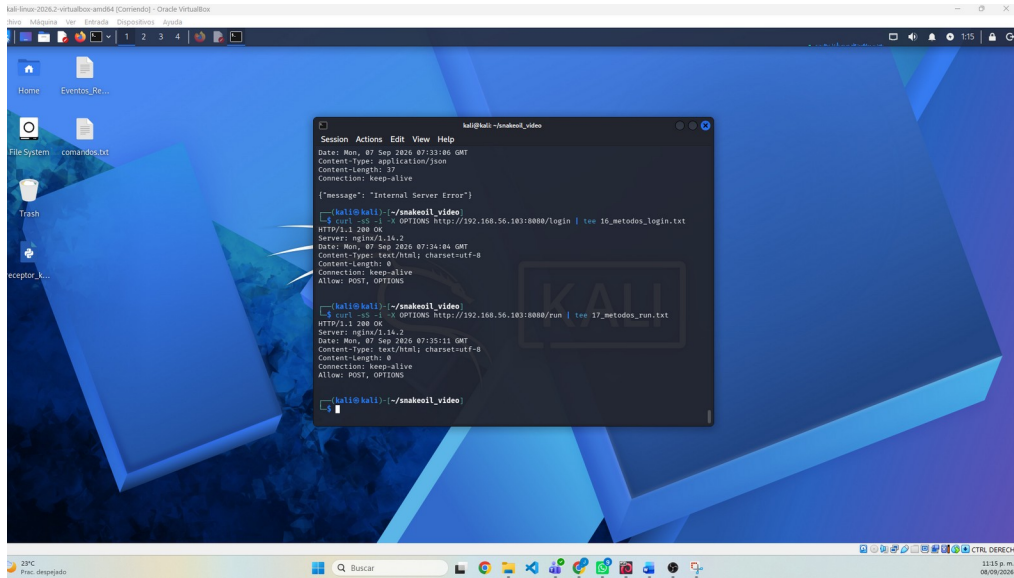


Figura 18. Respuestas obtenidas de los endpoints /test y /secret.

Ruta	Respuesta	Interpretación responsable
/test	HTTP 200; JSON {"TestValue": 0}	Endpoint de prueba expuesto; impacto no demostrado.
/secret	HTTP 500; Internal Server Error	Comportamiento anómalo; el 500 aislado no prueba una vulnerabilidad.

9.4 Métodos permitidos en /login y /run

Las solicitudes OPTIONS permitieron caracterizar ambos endpoints sin efectuar la operación principal. Tanto /login como /run devolvieron HTTP 200 y el encabezado Allow: POST, OPTIONS.



```
kali@kali:~/snakeoil_video$ curl -s -I -X OPTIONS http://192.168.56.103:8080/login | tee 16_metodos_login.txt
HTTP/1.1 200 OK
Server: nginx/1.14.2
Date: Mon, 07 Sep 2020 07:24:06 GMT
Content-Type: text/html; charset=utf-8
Content-Length: 0
Connection: keep-alive
Allow: POST, OPTIONS

kali@kali:~/snakeoil_video$ curl -s -I -X OPTIONS http://192.168.56.103:8080/run | tee 17_metodos_run.txt
HTTP/1.1 200 OK
Server: nginx/1.14.2
Date: Mon, 07 Sep 2020 07:25:11 GMT
Content-Type: text/html; charset=utf-8
Content-Length: 0
Connection: keep-alive
Allow: POST, OPTIONS
```

Figura 19. Métodos HTTP declarados por /login y /run.

Conclusión de la validación actual: Se confirmó la superficie de entrada, pero todavía no se conocen los campos requeridos, el mecanismo JWT ni las validaciones aplicadas. No se envió ningún cuerpo POST a /login, /registration, /create o /run.

10. Explotación controlada y acceso inicial

Estado: PENDIENTE. Antes de esta fase deberá conservarse una instantánea de la máquina y verificarse nuevamente que el objetivo sea 192.168.56.103 dentro de la red aislada.

10.1 Prueba de concepto seleccionada

FIGURA 20 - PENDIENTE

Insertar captura del comando o solicitud exacta utilizada para comprobar la vulnerabilidad seleccionada.

Completar después: Vulnerabilidad | Prerequisito | Comando/solicitud | Resultado esperado

FIGURA 21 - PENDIENTE

Insertar captura de la respuesta que confirme o descarte la explotación. Evitar registrar como éxito una respuesta ambigua.

Completar después: Código de respuesta | Indicador de éxito | Alcance | Limitaciones

10.2 Acceso inicial

FIGURA 22 - PENDIENTE

Insertar evidencia del acceso inicial autorizado e identificar usuario, host y contexto de ejecución.

Completar después: Usuario | Hostname | UID/GID | Tipo de acceso

Narrativa pendiente: explicar la relación causal entre el hallazgo, la prueba de concepto y el acceso obtenido. Incluir el principio vulnerado y una mitigación inmediata.

11. Post-explotación y escalamiento de privilegios

Estado: PENDIENTE. La enumeración posterior deberá limitarse a la máquina Snakeoil y a la información necesaria para demostrar el objetivo académico.

11.1 Verificación del contexto

FIGURA 23 - PENDIENTE

Insertar captura legible de whoami, id, hostname y datos mínimos del sistema tras obtener acceso.

Completar después: Usuario inicial | Grupos | Sistema | Directorio de trabajo

11.2 Enumeración local y vector de escalamiento

FIGURA 24 - PENDIENTE

Insertar la evidencia que sustente el vector local seleccionado, explicando por qué representa un riesgo.

Completar después: Configuración vulnerable | Permisos | Prerequisitos | Impacto

FIGURA 25 - PENDIENTE

Insertar captura final que demuestre el privilegio administrativo y, si aplica, la bandera del reto.

Completar después: Usuario final | Prueba de privilegio | Bandera | Fecha/hora

Cierre pendiente: registrar los cambios efectuados, restaurar la instantánea original si es necesario y confirmar que ninguna máquina vulnerable quede conectada a una red externa.

12. Explicación integral, riesgos y mitigación

Estado: PENDIENTE DE LOS RESULTADOS FINALES. Esta sección convertirá la secuencia técnica en una explicación comprensible, reproducible y orientada a defensa.

12.1 Cadena completa del ataque

Etapa	Entrada/evidencia	Resultado	Control defensivo
Reconocimiento	IP, puertos y servicios	192.168.56.103; TCP 22, 80 y 8080	Segmentación y mínima exposición
Enumeración	Rutas, respuestas y métodos	Usuario/hash expuestos; POST identificado	Control de acceso y manejo de errores
Explotación	Vulnerabilidad confirmada	PENDIENTE	Validación de entradas y configuración segura
Escalamiento	Vector local confirmado	PENDIENTE	Mínimo privilegio y permisos seguros

12.2 Matriz final de hallazgos

ID	Hallazgo	Evidencia	Severidad	Recomendación
F-01	Exposición de usuario y hash en /users	Figura 16	Media (preliminar)	Exigir autenticación y omitir hashes de las respuestas
F-02	Error interno reproducible en /secret	Figura 18	Por evaluar	Controlar excepciones y registrar el detalle solo en el servidor
F-03	PENDIENTE	Figura __	Por evaluar	Completar después de validar

12.3 Guion sugerido para el video

1. Presentar el objetivo, el alcance autorizado y la topología aislada.
2. Comenzar la demostración técnica en la fase 3 con la IP de Kali.
3. Mostrar descubrimiento, escaneo y enumeración explicando cada parámetro.
4. Demostrar únicamente los hallazgos confirmados y su impacto.
5. Ejecutar la prueba de concepto, acceso inicial y escalamiento de forma reproducible.
6. Cerrar con mitigaciones, aprendizaje obtenido y restauración segura del laboratorio.

Conclusiones del avance actual

El laboratorio quedó operativo y correctamente segmentado. Snakeoil fue localizada de forma inequívoca mediante su dirección MAC e IP, y el escaneo integral redujo la superficie inicial a tres servicios TCP. El puerto 8080 concentra la aplicación con mayor funcionalidad y produjo rutas adicionales durante la enumeración automática.

La fase de validación confirmó que /users expone sin autenticación aparente el usuario patrick y un hash PBKDF2-SHA256, por lo que se registra una divulgación de información de severidad media preliminar. También se verificó que /login y /run aceptan POST y OPTIONS, que /test devuelve un valor de prueba y que /secret produce un error interno genérico. Todavía no se ha realizado autenticación, recuperación de contraseñas, ejecución de comandos, explotación ni acceso al sistema. El siguiente paso responsable es auditar el hash de forma offline dentro del laboratorio y caracterizar los formatos POST esperados antes de elegir una prueba de concepto.

Registro de comandos ejecutados

Comando	Finalidad
ip -br addr	Identificar la IP y el prefijo de red de Kali.
sudo nmap -sn 192.168.56.0/24	Descubrir hosts activos dentro del segmento aislado.
sudo nmap -sS -sV -sC -O -p- 192.168.56.103 -oN snakeoil_escaneo_completo.txt	Enumerar todos los puertos TCP, versiones, scripts básicos y sistema operativo aproximado.
gobuster dir -u http://192.168.56.103:8080 -w /usr/share/wordlists/dirb/common.txt -x txt,html,py -o gobuster_8080.txt	Descubrir rutas y archivos no enlazados desde la interfaz.
curl -sS -i http://192.168.56.103:8080/users	Revisar encabezados y contenido del endpoint /users.
curl -sS -i http://192.168.56.103:8080/registration	Observar la respuesta de registro ante una solicitud GET.
curl -sS -i http://192.168.56.103:8080/create	Inspeccionar la vista HTML de creación sin enviar datos.
curl -sS -i http://192.168.56.103:8080/test	Comprobar la respuesta del endpoint de prueba.
curl -sS -i http://192.168.56.103:8080/secret	Registrar de forma reproducible el error interno del endpoint.
curl -sS -i -X OPTIONS http://192.168.56.103:8080/login	Identificar los métodos permitidos por /login.
curl -sS -i -X OPTIONS http://192.168.56.103:8080/run	Identificar los métodos permitidos por /run sin ejecutar comandos.

Referencias

1. VulnHub. digitalworld.local: snakeoil. <https://www.vulnhub.com/entry/digitalworldlocal-snakeoil,738/>
2. Nmap Project. Nmap Reference Guide. <https://nmap.org/book/man.html>

3. Gobuster Project. Directory/File, DNS and VHost busting tool. <https://github.com/OJ/gobuster>
4. Flask-JWT-Extended. Configuration Options.
<https://flask-jwt-extended.readthedocs.io/en/stable/options/>

Evidencia audiovisual

La evidencia audiovisual de PR01 está disponible en Microsoft Stream mediante el enlace institucional proporcionado para esta entrega: [Abrir video walkthrough de PR01](#). El acceso puede solicitar autenticación con una cuenta de la UPSLP.

Control de versión: Documento actualizado con evidencias disponibles hasta el 8 de septiembre de 2026. La fase 9 está en proceso; las secciones 10 y 11 conservan espacios explícitos para las capturas de explotación y post-explotación, mientras que la fase 12 se actualizará con la evaluación final.